

AtlasPay FinTech - SOC 2 Type 1 Executive Briefing

Executive Briefing

DOCUMENT ID

IJZ-ATL-SOC2-EB-20260625

VERSION

v4.0

PERIOD

FY 2026 Q3 Audit Window

PREPARED FOR

AtlasPay Board, CISO, CTO

PREPARED BY

Ijezie Risk Advisory

STATUS

Draft - Pending Review

AtlasPay FinTech - SOC 2 Type 1 Executive Briefing

Engagement: AtlasPay FinTech SOC 2 Type 1 Readiness Assessment **Period:** FY 2026 Q3 audit window (target)
Scope: Common Criteria (CC) + Availability (A) + Confidentiality (C) **Excluded:** Processing Integrity (PI), Privacy (P) - not in scope for this engagement **Framework:** SOC 2 Trust Services Criteria, Revision 2022 **Reference:** urn:intuitem:risk:library:soc2-2017-rev-2022 (loaded in CISO Assistant v3.18.3)

Status Legend

- **Covered** - Control is designed and operating; evidence available
- **Partial** - Control exists but evidence is incomplete or remediation in progress
- **Missing** - Control does not exist or no evidence available
- **[LAB-SYNTHETIC]** - Evidence item is fabricated for portfolio demonstration; clearly marked; do not replicate for real client work without proper authorization

Executive Summary

AtlasPay FinTech is preparing for SOC 2 Type 1 audit in FY 2026 Q3. This engagement spans **6 risk scenarios**, **22 SOC 2 Common Criteria**, and **7 third-party vendors** under management. The current readiness posture is **partial-to-covered** across the Common Criteria, with the highest residual risk concentrated in **third-party supply chain compromise** (R-04) and **insider threat** (R-05), both retained as **High** after treatment due to fundamental architectural exposure that exceeds engagement scope.

Engagement Scope

DIMENSION	COUNT	NOTES
Risk scenarios	6	All loaded in CISO Assistant risk assessment container RA-ATLASPAY-SOC2
SOC 2 Common Criteria	22	Spans CC1-CC9 (all common criteria sections)
Trust Services Categories	3	CC, A (Availability), C (Confidentiality)
Excluded categories	2	PI (Processing Integrity), P (Privacy)
Policies documented	4	SA-01, ACC-01, IR-01, TPRM-01
Third-party vendors	7	V-01 to V-07 under MSA with security addenda
Risk matrix	5x5	Custom ISO 27005-based scoring

Key Findings

- 1. Identity & Access Management is mature.** CC6.1 (logical access software), CC6.6 (encryption at rest), CC6.7 (transmission encryption) are all Covered with V-03 (Identity Provider) enforcing SSO + MFA.

2. **Vulnerability Management is partial.** CC7.1 has lab-synthetic evidence pending Q4 2026 validation against external penetration test results.
3. **Third-Party Risk is the dominant residual risk.** R-04 (Vendor Compromise) remains High after treatment because supply-chain compromise is endemic in FinTech; mitigation focuses on blast-radius reduction rather than risk elimination.
4. **Board Oversight documentation is in draft.** CC1.2 evidence is lab-synthetic (Risk Committee charter drafted 2026-06).
5. **Incident Response is well-designed.** CC7.2, CC7.3, CC7.4 all Covered with centralized SIEM (V-05) and documented IR-01 policy.

Headline Risks

ID	RISK	INHERENT	RESIDUAL	TREATMENT	OWNER
R-01	Privileged Account Compromise	High (4)	Medium (3)	Mitigate	CISO
R-02	Payment Data Exfiltration via API	Very High (5)	Medium (3)	Mitigate	CISO + CTO
R-03	Ransomware on Production Database	High (4)	Medium (3)	Mitigate	CTO + CISO
R-04	Third-Party SaaS Breach	High (4)	High (4)	Accept	CISO
R-05	Insider Threat (Malicious or Negligent)	High (4)	High (4)	Accept	CISO + HR
R-06	Audit Logging Failure (SIEM Gap)	Medium (3)	Low (2)	Mitigate	CTO

Residual risks R-04 and R-05 remain High because the controls in scope cannot eliminate the source: supply-chain compromise is industry-endemic, and insider risk requires behavioral controls outside the engagement boundary. These residuals are explicitly accepted by the CISO with documented rationale.

Risk Posture Summary

Risk Matrix (5x5)

The AtlasPay risk matrix plots **inherent** vs **residual** position for all 6 risk scenarios. Cells colored by severity. Notation: (inh) = inherent risk position; (res) = residual risk position after controls.

LIKELIHOOD	NEGLIGIBLE (1)	MINOR (2)	SERIOUS (3)	CRITICAL (4)	CATASTROPHIC (5)
Almost Certain (5)	-	-	-	-	-
Very Likely (4)	-	-	-	R-04 (inh)	R-02 (inh)
Likely (3)	-	-	R-03 (inh)	-	-
Rather Unlikely (2)	-	-	R-02 (res), R-03 (res)	-	-
Unlikely (1)	-	R-06 (res)	R-01 (res)	R-04 (res), R-05 (res)	-

Notation: (inh) = inherent risk, (res) = residual risk after controls. Empty cells (-) indicate no risks currently at that combination.

Treatment Distribution

- **Mitigate (4):** R-01, R-02, R-03, R-06 - controls reduce inherent risk to acceptable levels
- **Accept (2):** R-04, R-05 - residuals remain High due to scope-boundary limitations, accepted by CISO with documented rationale

Risk Owners

- **CISO** owns 3 risks (R-01, R-04, R-05)
- **CTO** owns 1 risk (R-06)
- **Joint CISO+CTO** owns 2 risks (R-02, R-03)
- **HR co-owns** R-05 (insider threat) for behavioral controls

Control Coverage Summary

Common Criteria (CC) - Status by Section

SECTION	DOMAIN	COVERED	PARTIAL	MISSING	TOTAL
CC1	Control Environment	0	5	0	5
CC2	Information and Communication	0	4	0	4
CC3	Risk Assessment	4	1	0	5
CC4	Monitoring Activities	0	2	0	2
CC5	Control Activities	0	3	0	3
CC6	Logical and Physical Access	5	3	0	8
CC7	System Operations	3	2	0	5
CC8	Change Management	0	2	0	2
CC9	Risk Mitigation	0	2	0	2
Total		12	24	0	36 evaluations

Note: 22 unique Common Criteria, with several criteria evaluated under multiple sub-criteria (36 total evaluations).

Trust Services Criteria (A + C)

CATEGORY	CRITERION	STATUS
A1.1	Capacity planning and availability commitments	

CATEGORY	CRITERION	STATUS
		Partial
A1.2	Environmental protections	Covered (V-01 AWS)
A1.3	Backup and recovery	Partial
C1.1	Identify confidential information	Covered
C1.2	Dispose of confidential information	Partial
C1.3	Protect against unauthorized access during transmission	Covered

Third-Party Risk Posture

Vendor Inventory

ID	VENDOR	FUNCTION	TIER	SOC 2 STATUS	CRITICALITY
V-01	AWS	Cloud Infrastructure	Tier-1	SOC 2 Type 2	Critical
V-02	Payment Gateway	Card Processing	Tier-1	PCI-DSS, SOC 2 pending	Critical
V-03	Identity Provider	SSO / MFA	Tier-1	SOC 2 Type 2	Critical
V-04	Application Platform	K8s Service Mesh	Tier-2	SOC 2 Type 1	High
V-05	Monitoring Tools	SIEM / EDR	Tier-1	SOC 2 Type 2	Critical
V-06	Customer Support SaaS	Ticketing	Tier-3	Self-attested	Medium
V-07	Email Provider	Transactional Email	Tier-3	SOC 2 Type 2	Low

TPRM Program Maturity

- 7 of 7 vendors under MSA with security addenda
- Tier-1 vendors (V-01, V-02, V-03, V-05) under annual SOC 2 Type 2 review cycle
- Contractual breach notification SLAs (72 hours) in all Tier-1 MSAs
- Tier-3 vendor (V-06) relies on self-attestation; gap noted in CC9.2
- Vendor risk scoring rubric (drafted 2026-06, awaiting CISO sign-off) - [LAB-SYNTHETIC]

Audit Walkthrough Readiness

Evidence Available

EVIDENCE TYPE	COUNT	STATUS
Policy documents	4	All approved and version-controlled
Risk register entries	6	All in CISO Assistant
Vendor SOC 2 reports	6 of 7	V-06 self-attestation only
Penetration test reports	1 of 4	Quarterly cadence not yet established
Backup restore test records	4	Quarterly cadence established
Incident response tabletop	1	Annual cadence pending
Board reporting minutes	0	Q3 2026 first meeting - [LAB-SYNTHETIC]
Access review evidence	2	Quarterly cadence established 2026-Q2

Auditor Walkthrough Plan

1. **Day 1 Morning:** CISO + CTO walkthrough of risk register and treatment plans (R-01 through R-06)
2. **Day 1 Afternoon:** Engineering walkthrough of access controls (CC6.1, CC6.6, CC6.7) with V-03
3. **Day 2 Morning:** Operations walkthrough of change management (CC8.1) and backup/restore (A1.3)
4. **Day 2 Afternoon:** Vendor management walkthrough (CC9.2) with TPRM-01 policy review

Recommended Path to Audit Readiness

Critical Path (must complete before audit window opens)

1. **Q3 2026:** Finalize Board Oversight documentation (CC1.2) - convert lab-synthetic evidence to actual Risk Committee meeting minutes
2. **Q3 2026:** Complete V-06 (Customer Support SaaS) SOC 2 Type 1 or migrate to alternative vendor
3. **Q3 2026:** Conduct annual incident response tabletop exercise
4. **Q3 2026:** Execute Q3 external penetration test, document results for CC7.1

Nice-to-Have (improves audit posture but not blockers)

1. **Q4 2026:** Implement automated user provisioning/deprovisioning via V-03 (CC6.2, CC6.3)
2. **Q4 2026:** Establish quarterly external penetration test cadence (CC7.1)
3. **Q4 2026:** Deploy automated policy attestation via HR system (CC1.5)
4. **Q4 2026:** Hot-standby disaster recovery site (currently backup-only)

Deferred Items (out of scope for FY 2026 Q3 audit)

- **Zero-trust network segmentation** - architectural change beyond engagement scope
- **Behavioral analytics for insider threat** - R-05 residual remains High, accepted
- **Supply chain diversification** - R-04 residual remains High, accepted

Engagement Artifacts

All artifacts are stored in the AtlasPay SOC 2 engagement repository at github.com/ijeziermf/atlaspay-grc-sandbox :

ARTIFACT	PATH	AUDIENCE
AtlasPay_SOC2_Executive_Briefing_v4.pdf	deliverables/ AtlasPay_SOC2_Executive_Briefing_v4.pdf	Board, CISO, CTO
AtlasPay_SOC2_Risk_Register_v4.pdf	deliverables/ AtlasPay_SOC2_Risk_Register_v4.pdf	Board, CISO, Engineering Leads
AtlasPay_SOC2_Control_Mapping_v4.pdf	deliverables/ AtlasPay_SOC2_Control_Mapping_v4.pdf	Auditors, Engineering
AtlasPay_SOC2_Gap_Assessment_v4.pdf	deliverables/ AtlasPay_SOC2_Gap_Assessment_v4.pdf	CISO, Engineering Leads
AtlasPay_SOC2_Audit_Walkthrough_v4.pdf	deliverables/ AtlasPay_SOC2_Audit_Walkthrough_v4.pdf	Auditors
CISO Assistant state	lab/ca_state_export.json	Engineering, Auditors
Lab docs (working papers)	lab/docs/	Ijezie Risk Advisory internal

Sign-Off

This executive briefing reflects the engagement state as of **2026-06-25**. The data in CISO Assistant v3.18.3 is the source of truth for all risk and control information. Lab-synthetic items are clearly marked and do not represent verified client evidence.

Prepared by: Ijezie Risk Advisory **Audience:** AtlasPay Board, CISO, CTO **Next review:** FY 2026 Q3 audit kickoff